

Cumplimiento Normativo y Auditoría

Objetivo: Asegurar que NovaTech Solutions opere bajo el marco legal vigente en México y cumpla con los estándares internacionales de seguridad, garantizando la confianza de los clientes y la protección jurídica de la empresa

Marco Legal y Regulatorio Aplicable

NovaTech Identifica y se compromete al cumplimiento de las siguientes normativas

1) Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP):

- a) **Aplicación:** Tratamiento de datos de los 120 empleados y bases de datos de clientes en el CRM
- b) **Acciones:** Implementación de Avisos de Privacidad, designación de un Oficial de privacidad y protocolos para el ejercicio de derechos ARCO

2) Ley Federal del Derecho de Autor y Propiedad Industrial:

- a) **Aplicación:** Protección del código fuente de las plataformas SaaS y software a medida desarrollado por la empresa.
- b) **Acciones:** Cláusulas de confidencialidad en contratos laborales y registro de activos intelectuales.

3) Código Fiscal de la federación:

- a) **Aplicación:** Integridad y disponibilidad de la información financiera y facturación.

Estándares Internacionales

NovaTech utiliza la norma ISO 27001 como base para su SGSI, enfocándose en los siguientes dominios críticos:

- **A.5 Control organizacional:** Asegura que la seguridad sea parte de la estrategia directiva.
- **A.8 Control tecnológico:** Implementar MFA (Autenticación Multi-Factor) y cifrado en bases de datos para evitar los incidentes de acceso no autorizado previamente reportados.
- **A.12 Seguridad en el desarrollo:** Garantizar que los repositorios Git tengan controles de acceso estrictos

Sistema de Métricas de Cumplimiento

Indicador	Descripción	Meta
Índice de hallazgos legales	Incumplimientos detectados en revisiones de contratos o avisos de privacidad	0 hallazgos
Disponibilidad de servicios	Tiempo de actividad de los sistemas críticos (evitar caídas prolongadas)	99.9% mensual
Eficacia de controles	Porcentaje de controles técnicos (MFA, Cifrado) operando correctamente	100%
Atención de derechos ARCO	Tiempo de respuesta a solicitudes de datos de clientes	< 15 días hábiles

Programa de auditoría interna

- **Frecuencia:** Se realizará una auditoría interna integral cada 6 meses.
- **Alcance:** Revisión de logs de acceso a servidores, inspección de dispositivos móviles de la empresa y validación de certificados de capacitación personal.
- **Responsables:** El comité de seguridad de la información o un auditor externo independiente.
- **Proceso de hallazgos**
 - **Identificación:** Registro de no conformidades
 - **Análisis de causa raíz:** Determinar por qué falló el control
 - **Plan de acción:** Implementar medidas correctivas en un plazo no mayor a 30 días.

Mejora continua

NovaTech adopta el ciclo de Deming (PLAN-DO-CHECK-ACT)

- **Actuar:** Los resultados de las auditorías y las métricas se presentan a la dirección general para asignar presupuesto y recursos, cerrando el ciclo de seguridad y garantizando que el SGSI evolucione junto con los riesgos tecnológicos.